POUR ALLER PLUS LOIN

- Avant le mise en production d'une API, vérifier sa résistance aux risques publiés par l'OWASP dans son **Top 10 API**[131].
- Voir la recommandation de la CNIL[132] relative au partage sécurisé de données par API.
- L'implémentation de l'API doit être mise en œuvre dans le respect de mesures de sécurité standards telles que la mise en place d'un **mécanisme d'authentification adapté** (voir la fiche n°4 - Authentifier les utilisateurs), la gestion périodique des habilitations (voir la fiche n°5 - Gérer les habilitations) ou encore le **chiffrement des communications** à l'état de l'art.
- Une version « bac à sable » de l'API devrait être mise à disposition afin de permettre des expérimentations et de tester les résultats attendus à partir de données fictives.

131 « OWASP API Security Top 10 », owasp.org

132 « API : les recommandations de la CNIL sur le partage de données », cnil.fr